

■ PROFESSIONAL INTELLIGENCE SERIES

CYBERSECURITY & ETHICAL HACKING

Complete Professional Guide

An in-depth examination of modern cybersecurity principles, threat landscapes, ethical hacking methodologies, encryption, incident response, and emerging security technologies.

10

CHAPTERS

200K+

THREATS ANALYZED

2024

EDITION

TABLE OF CONTENTS

Document Overview

01	Introduction to Cybersecurity	3
02	Types of Cyber Threats	4
03	Ethical Hacking Methodology	5
04	Network Security Fundamentals	6
05	Web Application Security	7
06	Cryptography and Encryption	8
07	Incident Response and Recovery	9
08	Security Best Practices	10
09	Legal and Compliance Framework	11
10	Future of Cybersecurity	12

CHAPTER 01

Introduction to Cybersecurity

Cybersecurity refers to the practice of protecting systems, networks, programs, and data from digital attacks. These cyberattacks are usually aimed at accessing, changing, or destroying sensitive information, extorting money from users, or interrupting normal business processes.

The global cost of cybercrime is projected to reach **\$10.5 trillion annually by 2025**, according to Cybersecurity Ventures. No organization is immune — from small businesses to multinational corporations and government agencies.

The CIA Triad

Principle	Definition	Example
Confidentiality	Data accessible only to authorized parties	Encryption, access controls
Integrity	Protection from unauthorized modification	Digital signatures, hashing
Availability	Systems accessible when needed	Redundancy, DDoS protection

Additional principles include **authentication** (verifying identities), **authorization** (granting appropriate permissions), and **non-repudiation** (ensuring actions cannot be denied later).

CHAPTER 02

Types of Cyber Threats

Understanding the threat landscape is the first step in building effective defenses. Modern cyber threats range from opportunistic malware to sophisticated nation-state attacks.

Malware Categories

- Viruses**

Attach to clean files and spread throughout systems. The ILOVEYOU virus (2000) caused approximately \$10 billion in damages.
- Worms**

Self-replicate without a host program. Conficker (2008) infected millions across 190 countries.
- Trojans**

Disguise as legitimate software. Zeus Trojan targeted banking credentials worldwide.
- Ransomware**

Encrypts files and demands payment. WannaCry (2017) affected 200,000+ computers across 150 countries.
- Spyware**

Secretly monitors activity. Keyloggers capture passwords and financial data.

Attack Vectors

Attack Type	Method	Impact Level
Phishing / Spear Phishing	Deceptive emails targeting credentials	HIGH
Man-in-the-Middle	Intercepts communications	HIGH
DDoS Attacks	Overwhelms systems with traffic	CRITICAL
APT (Advanced Persistent Threat)	Long-term stealthy intrusion	CRITICAL
Business Email Compromise	Impersonates executives for fraud	HIGH

CHAPTER 03

Ethical Hacking Methodology

Ethical hacking involves authorized attempts to bypass system security to identify vulnerabilities — using the same techniques as malicious hackers but with permission and within defined boundaries.

The Five Phases of Ethical Hacking

PHASE	DESCRIPTION
01 RECONNAISSANCE	Information gathering using passive (OSINT, DNS records, social media) and active (port scanning, network mapping) techniques.
02 SCANNING	Identifying live hosts, open ports, and services. Tools: Nmap, Nessus, OpenVAS, Qualys.
03 GAINING ACCESS	Exploiting vulnerabilities via SQL injection, XSS, buffer overflows, or social engineering.
04 MAINTAINING ACCESS	Installing backdoors, RATs, web shells, or scheduled tasks for persistent access.
05 COVERING TRACKS	Clearing logs, hiding files, using rootkits to conceal activity.

Professional Certifications

Acronym	Full Name	Issuing Body	Level
CEH	Certified Ethical Hacker	EC-Council	Entry–Mid
OSCP	Offensive Security Certified Professional	Offensive Security	Mid–Advanced
GPEN	GIAC Penetration Tester	GIAC	Mid–Advanced
PenTest+	CompTIA PenTest+	CompTIA	Mid-level

CHAPTER 04

Network Security Fundamentals

Network security protects the usability and integrity of network infrastructure and data through a layered combination of hardware, software, and procedural controls.

Firewalls

Monitor and control network traffic based on security rules. Types: Packet-filtering, Stateful Inspection, and Next-Generation Firewalls (NGFW) with deep packet inspection.

IDS / IPS

Intrusion Detection Systems alert administrators; Intrusion Prevention Systems actively block threats. Use signature-based or anomaly-based detection.

VPNs

Encrypt communications over untrusted networks using IPSec or SSL/TLS protocols to protect confidentiality and integrity.

Network Segmentation

Divides networks into subnets to contain breaches. Zero Trust architecture assumes no implicit trust, even within the perimeter.

NAC

Network Access Control enforces security policies — devices must meet requirements before gaining access.

Secure Network Protocols

Protocol	Purpose	Replaces
HTTPS	Encrypted web traffic (HTTP over TLS)	HTTP
SSH	Secure remote administration	Telnet
SFTP	Secure file transfers	FTP
SNMPv3	Authenticated network management	SNMPv1/v2
WPA3	Secure wireless encryption	WPA2

CHAPTER 05

Web Application Security

Web applications face unique security challenges due to their public accessibility and complexity. The OWASP Top 10 defines the most critical risks facing web applications today.

OWASP Top 10 (2021)

ID	Risk	Severity	Mitigation
A01	Broken Access Control	CRITICAL	Least privilege, access control checks
A02	Cryptographic Failures	HIGH	Strong TLS, modern algorithms, key management
A03	Injection	CRITICAL	Parameterized queries, input validation
A04	Insecure Design	HIGH	Threat modeling, secure SDLC
A05	Security Misconfiguration	HIGH	Hardening, config reviews, disable defaults
A06	Vulnerable Components	HIGH	Dependency management, SCA tools
A07	Auth Failures	HIGH	MFA, strong session management
A08	Software Integrity Failures	HIGH	Code signing, supply chain security
A09	Logging Failures	MEDIUM	Centralized logging, SIEM, alerting
A10	SSRF	HIGH	URL allowlists, network segmentation

■ SQL Injection Example

`SELECT * FROM users WHERE username = 'admin' -- ' AND password = 'anything'` → The comment sequence (--) bypasses password checking. Always use parameterized queries and prepared statements.

CHAPTER 06

Cryptography and Encryption

Cryptography underpins all modern security — protecting confidentiality, integrity, authentication, and non-repudiation through mathematical techniques.

Symmetric Encryption

Algorithm	Key Size	Status	Use Case
AES	128 / 192 / 256-bit	Current Standard	General purpose, TLS, storage
ChaCha20	Stream cipher	Modern	Mobile, TLS 1.3
3DES	112/168-bit	Being phased out	Legacy systems only
DES	56-bit	BROKEN	Do not use

Asymmetric Encryption

Algorithm	Based On	Recommended Key	Notes
RSA	Integer factorization	RSA-2048 or RSA-3072	RSA-1024 is broken
ECC	Elliptic curves	ECC-256	Smaller keys than RSA
Diffie-Hellman	Discrete logarithm	DH-2048+	Key exchange only

Hash Functions

Algorithm	Output Size	Status	Best For
SHA-256	256-bit	Secure	Data integrity, certificates
SHA-3	224–512-bit	Secure	Alternative to SHA-2
Argon2	Variable	Secure	Password hashing (winner of PHC)
bcrypt	Variable	Secure	Password hashing
MD5	128-bit	BROKEN	Do not use for security
SHA-1	160-bit	BROKEN	Do not use for security

CHAPTER 07

Incident Response and Recovery

A well-defined Incident Response Plan (IRP) provides structured processes for detecting, responding to, and recovering from security incidents, minimizing damage and recovery time.

NIST 800-61 — Six Phases of Incident Response

1	Preparation	Establish policies, form CSIRT, acquire tools, conduct training exercises before incidents occur.
2	Detection & Analysis	Identify incidents via SIEM, IDS, EDR, and user reports. Determine scope and severity.
3	Containment	Limit damage: disable accounts, block IPs, isolate systems. Short-term and long-term containment.
4	Eradication	Remove all threats: malware removal, patch vulnerabilities, delete backdoors, reimage systems.
5	Recovery	Restore operations safely. Monitor for reinfection, validate integrity, gradually restore services.
6	Lessons Learned	Review incident findings. Document successes and failures, update procedures, share intelligence.

Key Metrics

Metric	Description	Industry Benchmark
MTTD	Mean Time to Detect	< 24 hours (target)
MTTR	Mean Time to Respond	< 1 hour (target)
MTTC	Mean Time to Contain	< 4 hours (target)
Breach MTTD	Average detection time (industry)	> 200 days (reality)

CHAPTER 08

Security Best Practices

Effective security requires layered controls across organizational, technical, and individual levels — implementing defense-in-depth to ensure no single point of failure.

Organizational Controls

- Implement defense in depth (layered security controls)
- Follow the principle of least privilege (minimum necessary access)
- Conduct regular security awareness training for all employees
- Perform periodic risk assessments and penetration testing
- Maintain up-to-date asset inventory and software bill of materials (SBOM)

Technical Controls

- Keep all software patched and updated (vulnerability management)
- Use multi-factor authentication (MFA) everywhere possible
- Encrypt sensitive data at rest and in transit
- Implement strong password policies (length over complexity, no forced rotation)
- Back up critical data regularly with tested restoration procedures
- Segment networks to contain breaches and limit lateral movement
- Monitor logs and alert on suspicious behavior (SIEM)
- Deploy endpoint detection and response (EDR) on all endpoints
- Use application allowlisting instead of relying solely on antivirus

Personal Security Controls

- Never reuse passwords across different accounts or services
- Use a reputable password manager (Bitwarden, 1Password, KeePass)
- Enable automatic updates for all operating systems and applications
- Be highly suspicious of unexpected emails — check sender, hover over links
- Verify requests for sensitive information or money transfers via a second channel
- Lock your computer when stepping away, even briefly
- Avoid using public Wi-Fi without a trusted VPN connection

CHAPTER 09

Legal and Compliance Framework

Organizations must navigate a complex web of regulations and standards to protect data and avoid significant financial and reputational penalties.

Regulation	Full Name	Key Requirements	Penalties
GDPR	EU — General Data Protection Regulation	Right to access/rectify/erase data; breach notification within 72 hours.	Up to €20M or 4% of global annual revenue
PCI DSS	Payment Card Industry Data Security Standard	12 requirements: firewalls, encryption, access restrictions, logging, testing.	Fines + card brand penalties
HIPAA	Health Insurance Portability and Accountability Act (US)	Administrative, physical, and technical safeguards for health information (PHI).	Up to \$1.9M per violation category
SOX	Sarbanes-Oxley Act (US)	Audit trails and controls over financial data access for public companies.	Criminal penalties; prison time
ISO 27001	International ISMS Standard	Framework for security policies, risk assessments, and continuous improvement.	Certification-based
NIST CSF	NIST Cybersecurity Framework	Five functions: Identify, Protect, Detect, Respond, Recover.	Voluntary (US)

CHAPTER 10

Future of Cybersecurity

The threat landscape is evolving rapidly. Organizations must anticipate emerging threats while adopting next-generation defensive technologies to maintain a strong security posture.

Emerging Threats

- AI-powered attacks — generative AI enabling realistic phishing, automated vulnerability discovery, and polymorphic malware
- Quantum computing — threatens to break current public key cryptography (RSA, ECC) within a decade
- Deepfake technology — sophisticated social engineering and fraud using synthetic media
- Adversarial ML attacks — manipulating machine learning models (adversarial examples, model theft)
- Supply chain attacks — targeting dependencies and build pipelines (e.g., SolarWinds 2020)
- Ransomware targeting critical infrastructure — hospitals, utilities, transportation systems

Emerging Defenses

- Zero Trust Architecture — "never trust, always verify" regardless of network location
- Post-quantum cryptography — NIST-standardized algorithms resistant to quantum attacks
- AI for security analytics — anomaly detection and automated threat response at scale
- Confidential computing — hardware-based trusted execution environments (TEEs)
- XDR (Extended Detection and Response) — combining endpoint, network, and cloud security
- SOAR platforms — Security Orchestration, Automation, and Response for faster reaction
- Deception technology — honeypots, decoy documents, and fake credentials to trap attackers

■ Cybersecurity Talent Gap

The global cybersecurity workforce gap exceeds 3 million unfilled positions. Career opportunities span security analysis, penetration testing, forensics, incident response, cloud security, and executive leadership (CISO). Demand significantly outpaces supply, offering strong career prospects and compensation.